

Manual do Usuário

INCIDENT_SYS — Sistema Web Seguro para Registro e Classificação de Incidentes de Segurança Cibernética

Versão: 2.2

Data: Abril de 2026 (Sessão 10 — Documentação de Rotas)

Repositório: https://github.com/margefson/incident_security_system

Equipe: Nattan, Keven, Margefson, Josias

Sumário

1. [Visão Geral do Sistema](#)
2. [Acesso e Autenticação](#)
3. [Painel de Controle \(Dashboard\)](#)
4. [Registro de Incidentes](#)
5. [Listagem e Filtros de Incidentes](#)
 - [5.3 Filtros Disponíveis](#)
 - [5.4 Exportação CSV](#)
6. [Visualização Detalhada de Incidente](#)
7. [Análise de Risco](#)
8. [Classificação Automática por Machine Learning](#)
9. [Controle de Acesso e Segurança](#)
10. [Fluxos Completos do Sistema](#)
11. [Referência de Categorias e Níveis de Risco](#)
12. [Mensagens de Erro e Solução](#)
13. [Divisão de Atividades do Grupo](#)

1. Visão Geral do Sistema

O **INCIDENT_SYS** é uma plataforma web de gerenciamento de incidentes de segurança cibernética desenvolvida com arquitetura full-stack moderna. O sistema permite que analistas de segurança registrem, classifiquem e monitorem incidentes de forma estruturada, com classificação automática baseada em Machine Learning (TF-IDF + Naive Bayes) treinado sobre um dataset de 2000 amostras reais.

A interface adota o design **SOC Portal** — tema dark profissional com fundo #0d1117, tipografia Inter, sidebar compacta com ícones, badges coloridos por severidade e tabelas operacionais — projetada para ambientes de operações de segurança (SOC) onde a leitura rápida de informações críticas é essencial.

Tecnologias Utilizadas

Camada	Tecnologia	Finalidade
Frontend	React 19 + Vite + TypeScript	Interface de usuário reativa
Estilização	Tailwind CSS 4 + CSS Variables OKLCH	Design SOC Portal dark
API	tRPC 11 + Zod	Contratos tipados end-to-end
Backend	Node.js + Express 4	Servidor de aplicação
Banco de Dados	MySQL + Drizzle ORM	Persistência de dados
Autenticação	bcryptjs + JWT (jose)	Segurança de credenciais
Validação	Joi	Validação de entradas
Machine Learning	Python 3.11 + scikit-learn	Classificação automática
Servidor ML	Flask 3	API REST interna para previsões
Gráficos	Recharts	Visualizações do dashboard

2. Acesso e Autenticação

2.1 Página Inicial (Landing Page)

Ao acessar o sistema pela primeira vez, o usuário é recebido pela página inicial com apresentação das funcionalidades principais. A página exibe as cinco categorias de incidentes suportadas e os dois botões de ação: **ACESSAR SISTEMA** (login) e **CRIAR CONTA** (registro).

2.2 Criação de Conta (Registro)

Para criar uma nova conta, o usuário deve clicar em **CRIAR CONTA** e preencher o formulário com os seguintes campos obrigatórios:

Campo	Requisito	Validação
Nome completo	Obrigatório	Mínimo 2, máximo 100 caracteres
Endereço de e-mail	Obrigatório	Formato de e-mail válido, único no sistema
Senha	Obrigatório	Ver regras de complexidade abaixo

Após o envio, o sistema verifica se o e-mail já está cadastrado. Caso o e-mail seja inédito, a senha é armazenada com hash bcrypt (saltRounds = 12) e o usuário é redirecionado automaticamente para o Dashboard.

Regras de Complexidade da Senha

O sistema exige que a senha atenda **todos** os seguintes critérios simultaneamente:

Critério	Regra
Comprimento mínimo	8 caracteres
Comprimento máximo	128 caracteres
Letra minúscula	Pelo menos uma letra minúscula (a-z)
Letra maiúscula	Pelo menos uma letra maiúscula (A-Z)
Número	Pelo menos um dígito (0-9)
Caractere especial	Pelo menos um símbolo (ex.: ! , @ , # , \$, % , &)

Exemplo de senha válida: `Senha@123`

O formulário exibe um **checklist visual em tempo real** que indica quais critérios já foram atendidos conforme o usuário digita. Uma **barra de força** (Muito Fraca / Fraca / Média / Forte) também é exibida. O botão **CRIAR ACESSO** permanece desabilitado até que todos os seis critérios sejam satisfeitos.

Segurança: A senha nunca é armazenada em texto plano. O hash `bcrypt` com fator de custo 12 garante resistência a ataques de força bruta mesmo em caso de vazamento do banco de dados.

2.3 Login

O formulário de login solicita e-mail e senha. Após validação bem-sucedida, o sistema gera um cookie de sessão JWT assinado com `JWT_SECRET` e redireciona para o Dashboard. O cookie é configurado com as flags `HttpOnly: true`, `Secure: true` (em produção) e `SameSite: lax` para proteção contra XSS e CSRF.

2.4 Logout

O botão de logout está disponível na parte inferior da barra lateral esquerda. Ao clicar, o cookie de sessão é invalidado no servidor e o usuário é redirecionado para a página inicial.

3. Painel de Controle (Dashboard)

O Dashboard é a tela principal do sistema após autenticação. Ele apresenta uma visão consolidada de todos os incidentes do usuário autenticado.

3.1 Cards de Indicadores (KPIs)

Quatro cards de destaque exibem métricas em tempo real:

Indicador	Descrição	Cor
Total de Incidentes	Quantidade total de incidentes registrados pelo usuário	Ciano
Risco Crítico	Número de incidentes classificados como nível crítico	Vermelho
Categorias Ativas	Quantidade de categorias distintas presentes nos incidentes	Rosa
Precisão do Modelo	Acurácia do modelo ML em cross-validation (97%)	Verde

3.2 Gráfico de Incidentes por Categoria

Um gráfico de barras horizontal exibe a distribuição dos incidentes entre as cinco categorias de ameaça. Cada barra possui cor semântica distinta para identificação visual rápida. O gráfico é interativo: ao passar o cursor sobre uma barra, um tooltip exibe o valor exato.

3.3 Gráfico de Nível de Risco (Donut)

Um gráfico de rosca (donut) exibe a proporção de incidentes por nível de risco (Crítico, Alto, Médio, Baixo). Uma legenda lateral correlaciona cores e valores absolutos.

3.4 Incidentes Recentes

Uma lista dos cinco incidentes mais recentes é exibida na parte inferior do Dashboard. Cada item mostra título, data de registro, badge de categoria e badge de risco. Clicar em qualquer item navega para a visualização detalhada do incidente.

3.5 Informações do Modelo ML

Uma barra informativa na base do Dashboard confirma o status do motor de classificação: método utilizado (TF-IDF + Naive Bayes), tamanho do dataset de treinamento (2000 amostras) e acurácia em validação cruzada (97%).

4. Registro de Incidentes

4.1 Acessando o Formulário

O formulário de novo incidente pode ser acessado de três formas:

- Clicando em **NOVO INCIDENTE** no canto superior direito do Dashboard.
- Clicando em **Novo Incidente** na barra lateral esquerda.
- Clicando em + **Registrar primeiro incidente** quando a lista estiver vazia.

4.2 Preenchimento do Formulário

O formulário contém dois campos obrigatórios:

Título do Incidente Campo de texto de linha única. Deve descrever o incidente de forma concisa e objetiva. Requisitos de validação: mínimo de 3 caracteres, máximo de 255 caracteres. Um contador de caracteres é exibido em tempo real no canto inferior direito do campo.

Descrição Detalhada Campo de texto multilinha (redimensionável). Deve conter a descrição completa do incidente, incluindo: o que aconteceu, quando foi detectado, quais sistemas foram afetados e quais indicadores foram observados. Requisitos: mínimo de 10 caracteres, máximo de 5.000 caracteres.

4.3 Pré-visualização da Classificação

À medida que o usuário digita, o sistema executa uma análise léxica local (baseada em palavras-chave) e exibe uma **pré-visualização da categoria provável** antes mesmo do envio. Esta pré-visualização é indicativa; a classificação definitiva é realizada pelo modelo ML no servidor após o envio.

4.4 Processo de Classificação Automática

Ao clicar em **REGISTRAR E CLASSIFICAR**, o sistema executa o seguinte fluxo:

1. O backend Node.js valida os campos com o schema Joi.
2. O texto combinado (título + descrição) é enviado via HTTP POST para o servidor Flask interno (porta 5001).
3. O modelo TF-IDF + Naive Bayes processa o texto e retorna a categoria predita, o nível de risco associado e o score de confiança (0 a 1).
4. O incidente é persistido no banco de dados com todos os metadados de classificação.
5. O usuário é redirecionado para a página de detalhe do incidente recém-criado.

O botão de envio fica desabilitado enquanto os campos não atingem o comprimento mínimo, prevenindo envios inválidos.

5. Listagem e Filtros de Incidentes

5.1 Acessando a Listagem

A página de listagem é acessada clicando em **Meus Incidentes** na barra lateral. Ela exibe exclusivamente os incidentes do usuário autenticado — nenhum usuário pode visualizar incidentes de outro usuário.

5.2 Tabela de Incidentes

A tabela apresenta as seguintes colunas:

Coluna	Descrição
#ID	Identificador único do incidente
Título	Título e trecho da descrição
Categoria	Badge colorido com a categoria classificada
Risco	Badge com o nível de risco
Confiança	Score de confiança do modelo ML (em %)
Data	Data de registro (formato DD/MM/AAAA)
Ações	Botões de visualizar (olho) e excluir (lixeira)

5.3 Filtros Disponíveis

A barra de filtros acima da tabela oferece três controles independentes:

Busca por texto: Filtra incidentes cujo título ou descrição contenha o texto digitado. A busca é realizada em tempo real, sem necessidade de pressionar Enter.

Filtro por Categoria: Menu suspenso com as opções: Phishing, Malware, Força Bruta, DDoS, Vazamento. Selecionar uma categoria exibe apenas os incidentes dessa categoria.

Filtro por Risco: Menu suspenso com as opções: Crítico, Alto, Médio, Baixo. Os filtros de categoria e risco podem ser combinados simultaneamente.

O contador no cabeçalho da página exibe “X de Y registros” refletindo o número de itens visíveis após a aplicação dos filtros.

5.5 Exclusão de Incidente

Ao clicar no ícone de lixeira, uma caixa de confirmação é exibida. Após confirmação, o incidente é removido permanentemente do banco de dados e os contadores do Dashboard são atualizados automaticamente.

6. Visualização Detalhada de Incidente

6.1 Acessando o Detalhe

A página de detalhe é acessada clicando no ícone de olho na listagem ou em qualquer incidente da lista de recentes no Dashboard.

6.2 Informações Exibidas

Card de Cabeçalho: Exibe o ID do incidente, título completo, data e hora de registro. A borda do card adota a cor semântica do nível de risco do incidente, com corner brackets decorativos.

Card de Classificação ML: Apresenta a categoria classificada pelo modelo, a barra de progresso de confiança (percentual) e uma descrição explicativa da categoria.

Card de Análise de Risco: Apresenta o nível de risco atribuído e uma descrição das ações recomendadas para aquele nível.

Card de Descrição: Exibe o texto completo da descrição do incidente com preservação de quebras de linha.

6.3 Exclusão na Página de Detalhe

O botão de exclusão (ícone de lixeira) no canto superior direito do card de cabeçalho permite remover o incidente diretamente da página de detalhe, com confirmação prévia.

7. Análise de Risco

7.1 Acessando a Análise

A página de Análise de Risco é acessada clicando em **Análise de Risco** na barra lateral (ícone de atividade).

7.2 Score de Risco Geral

O sistema calcula um **score de risco consolidado** (0 a 100) com base em todos os incidentes do usuário. O cálculo pondera cada incidente pelo peso do seu nível de risco:

Nível de Risco	Peso
Crítico	4
Alto	3
Médio	2
Baixo	1

A fórmula aplicada é: $\text{Score} = (\text{Soma dos pesos} / \text{Máximo possível}) \times 100$. O score é exibido em destaque com cor semântica (verde para baixo, amarelo para médio, laranja para alto, vermelho para crítico).

7.3 Gráfico de Perfil de Ameaças (Radar)

Um gráfico radar exibe a distribuição dos incidentes por categoria em formato poligonal, permitindo identificar visualmente quais vetores de ataque são mais frequentes no ambiente monitorado.

7.4 Gráfico de Distribuição de Risco

Um gráfico de barras verticais exibe a contagem de incidentes por nível de risco, com cores semânticas (vermelho para crítico, laranja para alto, amarelo para médio, verde para baixo).

7.5 Recomendações de Segurança

Com base nos incidentes registrados, o sistema gera automaticamente recomendações contextualizadas por categoria. Cada recomendação exibe o título da ação, uma descrição do risco, o nível de prioridade (Crítico ou Alto) e a ação específica recomendada para mitigação.

As recomendações aparecem em dois locais:

1. **Tela de Análise de Risco** (`/risk`): Painel consolidado com todas as recomendações ativas, ordenadas por prioridade (crítico antes de alto). Exibe a contagem de incidentes de cada categoria e a ação recomendada.
2. **Detalhe do Incidente** (`/incidents/:id`): Ao abrir um incidente específico, o sistema exibe automaticamente a recomendação correspondente à categoria daquele incidente.

A tabela a seguir descreve as recomendações implementadas para cada categoria:

Categoria	Título da Recomendação	Prioridade	Ação Recomendada
Malware	Isolamento de Sistemas Comprometidos	Crítica	Isolar o sistema afetado da rede, executar varredura completa com antivírus atualizado e restaurar a partir de backup limpo.
Vazamento de Dados	Notificação ao DPO e Avaliação LGPD	Crítica	Notificar o DPO em até 72h, registrar o incidente, avaliar notificação à ANPD e comunicar os titulares afetados (LGPD Art. 48).
Phishing	Reforço de Treinamento de Conscientização	Alta	Realizar campanha de phishing simulado, atualizar treinamentos de segurança e habilitar MFA em todas as contas corporativas.
Força Bruta	Bloqueio Automático após Falhas de Login	Alta	Configurar lockout após 5 tentativas, habilitar CAPTCHA nos formulários de login e revisar a política de senhas.
DDoS	Revisão de Rate Limiting e CDN	Alta	Ativar proteção DDoS no CDN, revisar regras de rate limiting e configurar auto-scaling para absorver picos de tráfego.

As recomendações são geradas dinamicamente: somente categorias com pelo menos um incidente registrado ativam sua respectiva recomendação. Quando não há incidentes em categorias reconhecidas, o sistema exibe recomendações genéricas baseadas no nível de risco (crítico/alto).

8. Classificação Automática por Machine Learning

8.1 Arquitetura do Modelo

O motor de classificação é composto por um pipeline scikit-learn com duas etapas:

TF-IDF Vectorizer (Term Frequency–Inverse Document Frequency): Converte o texto do incidente em um vetor numérico ponderado, atribuindo maior peso a termos relevantes e menor peso a termos comuns. Configuração: `ngram_range=(1,2)`, `max_features=5000`, `sublinear_tf=True`.

Multinomial Naive Bayes: Classificador probabilístico que calcula a probabilidade posterior de cada categoria dado o vetor TF-IDF. Retorna a categoria com maior probabilidade e o score de confiança associado.

8.2 Dataset de Treinamento

O modelo foi treinado com o arquivo `incidentes_cybersecurity_2000.xlsx`, contendo 2000 amostras balanceadas (20 por categoria). Cada amostra possui título, descrição e categoria rotulada.

8.3 Métricas de Desempenho

Métrica	Valor
Acurácia no conjunto de treino	100%
Acurácia em cross-validation (5-fold)	97% ± 6%
Número de categorias	5
Tamanho do vocabulário TF-IDF	5.000 features

8.4 Categorias e Mapeamento de Risco

Categoria	Rótulo Interno	Nível de Risco Atribuído
Phishing	phishing	Alto
Malware	malware	Crítico
Ataque de Força Bruta	brute_force	Alto
Negação de Serviço (DDoS)	ddos	Médio
Vazamento de Dados	vazamento_de_dados	Crítico
Não classificado	unknown	Baixo

8.5 Fluxo de Classificação

O servidor Flask (porta 5001) é iniciado manualmente antes do servidor Node.js. A comunicação entre os dois servidores é interna (localhost), nunca exposta publicamente. O endpoint `/classify` recebe um JSON com `title` e `description`, processa o texto e retorna `category`, `confidence`, `risk_level` e `method`.

O campo `method` indica a origem da classificação:

Valor	Descrição
"ml"	Classificação realizada pelo modelo TF-IDF + Naive Bayes (servidor Flask disponível)
"keyword"	Classificação por palavras-chave (fallback automático quando o servidor Flask está indisponível)

8.6 Gestão do Dataset e Retreinamento (Admin)

Administradores têm acesso à tela **Machine Learning** (`/admin/ml`) com as seguintes funcionalidades:

Download do Dataset de Treinamento: O botão “Baixar Dataset” disponibiliza o arquivo `incidentes_cybersecurity_2000.xlsx` diretamente no navegador. O

arquivo contém as 2000 amostras originais (20 por categoria) usadas para treinar o modelo atual.

Métricas do Modelo: A tela exibe as métricas atuais do modelo (acurácia de treino, acurácia CV, tamanho do dataset, distribuição por categoria).

Retreinamento com Novas Categorias: A seção “Retreinar Modelo” permite que o administrador adicione novas amostras de treinamento para categorias existentes ou novas categorias que não fazem parte das 5 originais. O formulário solicita:

Campo	Obrigatório	Descrição
Título	Não	Título do incidente de exemplo
Descrição	Sim	Texto descritivo do incidente
Categoria	Sim	Rótulo da categoria (ex: <code>engenharia_social</code>)
Nível de Risco	Sim	<code>critical</code> , <code>high</code> , <code>medium</code> ou <code>low</code>

Após o treinamento, o modelo é atualizado imediatamente e as novas categorias passam a ser reconhecidas pelo endpoint `/classify`. As métricas de desempenho são exibidas na tela após o processo.

***Nota:** O treinamento é incremental — as novas amostras são adicionadas ao dataset existente antes de retreinar o modelo completo. Recomenda-se fornecer pelo menos 5 amostras por nova categoria para garantir boa acurácia.*

9. Controle de Acesso e Segurança

O sistema implementa **8 requisitos de segurança obrigatórios**, todos cobertos por testes automatizados individuais.

9.1 Gerenciamento de Segredos (Req. 6.1)

Nenhum segredo (senha de banco, chave JWT, etc.) aparece no código-fonte. Todos são lidos de variáveis de ambiente via arquivo `.env`. O arquivo `.env` nunca é versionado no repositório.

9.2 Hash de Senha com bcrypt (Req. 6.2)

As senhas são armazenadas exclusivamente como hash bcrypt com fator de custo 12. O sistema nunca registra senhas em logs ou as transmite após o momento do cadastro/login. O campo `passwordHash` nunca é retornado nas respostas da API.

9.3 Sessão Segura (Req. 6.3)

O cookie de sessão JWT é configurado com:

Flag	Valor	Propósito
<code>HttpOnly</code>	<code>true</code>	Inacessível via JavaScript (proteção XSS)
<code>Secure</code>	<code>true</code> em produção	Transmitido apenas via HTTPS
<code>SameSite</code>	<code>"lax"</code>	Proteção contra CSRF
<code>Path</code>	<code>"/"</code>	Válido para todas as rotas

9.4 Autorização nos Incidentes — Proteção IDOR (Req. 6.4)

Cada usuário autenticado tem acesso exclusivo aos seus próprios incidentes. Antes de qualquer operação de leitura, atualização ou remoção, o servidor verifica se o incidente pertence ao usuário autenticado. Caso não pertence, retorna **HTTP 404** (não encontrado) — nunca HTTP 403 — para não revelar a existência do recurso a terceiros.

9.5 Perfis de Usuário

Perfil	Permissões
<code>user</code> (padrão)	Criar, listar, visualizar e excluir apenas seus próprios incidentes
<code>admin</code>	Todas as permissões de <code>user</code> + acesso a incidentes de qualquer usuário + estatísticas globais + painel de administração

A promoção de um usuário para `admin` pode ser feita pelo painel de administração (por outro admin) ou diretamente no banco de dados.

9.6 Rate Limiting (Req. 6.5)

O sistema aplica dois limitadores de taxa para prevenir ataques de força bruta e abuso de API:

Limitador	Escopo	Limite
Global	Todas as rotas <code>/api/*</code>	100 req / IP / 15 min
Autenticação	Endpoints de login e registro	10 req / IP / 15 min

Ao atingir o limite, o servidor retorna **HTTP 429** com mensagem de erro.

9.7 CORS (Req. 6.6)

A API aceita requisições apenas da origem configurada via variável de ambiente `FRONTEND_URL`. Credenciais (cookies) são permitidas via `credentials: true`.

9.8 Cabeçalhos de Segurança HTTP (Req. 6.7)

O middleware `helmet` é aplicado globalmente, configurando:

- `X-Powered-By` removido (não revela tecnologia do servidor).
- `X-Content-Type-Options: nosniff` (previne MIME sniffing).
- `Strict-Transport-Security` com `max-age=31536000` (força HTTPS por 1 ano).
- `X-Frame-Options: SAMEORIGIN` (previne clickjacking).

9.9 Proteção contra Timing Attack (Req. 6.8)

A função de login executa `bcrypt.compare()` **sempre**, mesmo quando o e-mail informado não existe no banco de dados. Isso garante que o tempo de resposta seja idêntico para e-mails existentes e inexistentes, impedindo que atacantes enumerem usuários cadastrados por análise de tempo de resposta.

9. Segurança de Senha

9.1 Proteção contra Copiar/Colar

Por razões de segurança, os campos de senha em todas as telas do sistema (login, cadastro, alteração e redefinição) **não permitem** as operações de copiar, cortar ou colar. Ao tentar usar `Ctrl+C`, `Ctrl+X` ou `Ctrl+V` em um campo de senha, o sistema exibirá uma mensagem informando que a operação não é permitida.

Essa medida protege contra ataques de shoulder surfing e impede que senhas sejam inadvertidamente expostas na área de transferência.

9.2 Troca Obrigatória de Senha após Reset pelo Administrador

Quando o administrador redefine sua senha (para a senha padrão `Security2026@`), no próximo login você será redirecionado automaticamente para a página de perfil com um **banner amarelo de aviso**. Esse banner indica que você deve criar uma nova senha antes de continuar usando o sistema.

Passos para trocar a senha obrigatória:

1. Faça login com a senha padrão `Security2026@`
2. Você será redirecionado para `/perfil` com o aviso de troca obrigatória
3. Role até a seção **“Alterar Senha”** no final da página
4. Informe a senha atual (`Security2026@`), a nova senha e a confirmação
5. Clique em **“Alterar Senha”**
6. O banner desaparecerá e você poderá usar o sistema normalmente

9.3 Redefinição de Senha por E-mail (“Esqueci minha senha”)

Se você esqueceu sua senha, siga os passos abaixo:

1. Na tela de login, clique no link **“Esqueci minha senha”**
2. Informe seu **e-mail cadastrado** no sistema
3. Clique em **“Enviar Link de Redefinição”**

4. O sistema tentará enviar o link por e-mail automaticamente via **Resend** (serviço de e-mail transacional)

Cenário A — E-mail entregue com sucesso

Se o sistema conseguir entregar o e-mail:

- Você verá a mensagem **“E-mail enviado!”** na tela
- Acesse sua caixa de entrada (verifique também a pasta de **spam/lixo eletrônico**)
- Clique no link recebido — ele é válido por **apenas 10 minutos**

Cenário B — Link exibido diretamente na tela

Em ambientes de teste ou quando o serviço de e-mail está em modo restrito (domínio não verificado), o sistema exibirá o link diretamente na tela com um aviso amarelo:

“Link gerado com sucesso — O e-mail não pôde ser entregue automaticamente. Use o link abaixo para redefinir sua senha.”

Nesse caso:

- Clique no botão **“Abrir Link”** para ir diretamente à página de redefinição, **ou**
- Clique em **“Copiar Link”** para copiar o endereço e colá-lo no navegador
- O link continua válido por **10 minutos** a partir da solicitação

Passos finais (ambos os cenários)

1. Na página de redefinição, crie uma nova senha forte
2. Clique em **“Redefinir Senha”**
3. Você será redirecionado para o login para entrar com a nova senha

Atenção: O link de redefinição pode ser usado apenas uma vez. Após o uso, ele é invalidado automaticamente. Por segurança, o sistema não informa se o e-mail está ou não cadastrado (prevenção de enumeração de e-mails).

9.4 Requisitos de Senha

Sua senha deve atender aos seguintes requisitos mínimos:

- Pelo menos **8 caracteres**
- Recomendado: letras maiúsculas, minúsculas, números e caracteres especiais

10. Fluxos Completos do Sistema

Fluxo 1: Primeiro Acesso e Registro

```
Usuário acessa a URL → Página Inicial
→ Clica em "CRIAR CONTA"
→ Preenche nome, e-mail, senha, confirmação
→ Sistema valida (Joi) → bcrypt hash da senha
→ Usuário criado no banco → Cookie JWT gerado
→ Redirecionamento para Dashboard
```

Fluxo 2: Login de Usuário Existente

```
Usuário acessa a URL → Página Inicial
→ Clica em "ACESSAR SISTEMA"
→ Preenche e-mail e senha
→ Sistema busca usuário por e-mail
→ bcrypt.compare(senha, hash) → OK
→ Cookie JWT gerado → Redirecionamento para Dashboard
```

Fluxo 3: Registro e Classificação de Incidente

```
Usuário autenticado → Clica em "NOVO INCIDENTE"
→ Preenche título e descrição
→ Sistema exibe pré-visualização de categoria (client-side)
→ Clica em "REGISTRAR E CLASSIFICAR"
→ Backend valida com Joi
→ Texto enviado para Flask /classify (porta 5001)
→ TF-IDF vetoriza → Naive Bayes classifica
→ Retorna: categoria, confiança, nível de risco
→ Incidente salvo no banco com metadados ML
→ Redirecionamento para página de detalhe
```

Fluxo 4: Consulta e Análise de Incidentes

Usuário autenticado → Clica em "Meus Incidentes"

- Sistema busca incidentes WHERE userId = ctx.user.id
- Tabela exibida com filtros disponíveis
- Usuário aplica filtros por categoria/risco/texto
- Clica em incidente → Página de detalhe
- Visualiza classificação, confiança, análise de risco

Fluxo 5: Análise de Risco Consolidada

Usuário autenticado → Clica em "Análise de Risco"

- Sistema agrega incidentes por categoria e risco
- Score de risco **calculado** (ponderado)
- Gráficos radar e barras renderizados
- Recomendações geradas com **base** nos dados reais

11. Referência de Categorias e Níveis de Risco

Categorias de Incidentes

Phishing — Tentativas de engenharia social para obter credenciais ou informações sensíveis através de e-mails, mensagens ou sites fraudulentos. Palavras-chave típicas: e-mail suspeito, link malicioso, credenciais, fraude, identidade falsa.

Malware — Software malicioso projetado para danificar, comprometer ou obter acesso não autorizado a sistemas. Inclui vírus, trojans, ransomware, spyware e backdoors. Palavras-chave típicas: executável suspeito, vírus, ransomware, backdoor, script malicioso.

Força Bruta (Brute Force) — Ataques automatizados que tentam adivinhar credenciais através de múltiplas tentativas consecutivas de login. Palavras-chave típicas: tentativas de login, falhas consecutivas, bloqueio de conta, dicionário de senhas.

DDoS — Ataques de negação de serviço distribuído que visam tornar sistemas ou serviços indisponíveis através de sobrecarga de tráfego. Palavras-chave típicas: tráfego anômalo, sobrecarga, indisponibilidade, requisições excessivas.

Vazamento de Dados — Exposição não autorizada de dados sensíveis, seja por acidente (misconfiguration) ou ação maliciosa (exfiltração). Palavras-chave típicas: dados expostos, arquivo não autorizado, planilha vazada, acesso indevido.

Níveis de Risco

Nível	Cor	Ação Recomendada
Crítico	Vermelho	Resposta imediata. Acionar equipe de segurança e isolar sistemas afetados.
Alto	Laranja	Resposta urgente nas próximas horas. Escalar para analista sênior.
Médio	Amarelo	Tratar no ciclo normal de resposta a incidentes (24–72 horas).
Baixo	Verde	Monitorar e documentar. Incluir na análise de tendências mensal.

12. Mensagens de Erro e Solução

Mensagem	Causa	Solução
“Email já cadastrado”	E-mail já existe no banco	Utilizar outro e-mail ou recuperar a senha
“Credenciais inválidas”	E-mail ou senha incorretos	Verificar e-mail e senha digitados
“Título deve ter pelo menos 3 caracteres”	Campo título muito curto	Ampliar o título do incidente
“Descrição deve ter pelo menos 10 caracteres”	Campo descrição muito curto	Detalhar mais a descrição
“Acesso negado”	Tentativa de acessar incidente de outro usuário	Verificar se o ID do incidente pertence ao usuário
“Incidente não encontrado”	ID inválido ou incidente excluído	Retornar à listagem e selecionar um incidente válido
“Apenas administradores”	Acesso a recurso restrito a admin	Solicitar elevação de privilégios ao administrador
“Senha deve conter pelo menos: uppercase”	Falta letra maiúscula	Adicionar ao menos uma letra maiúscula (A–Z)
“Senha deve conter pelo menos: lowercase”	Falta letra minúscula	Adicionar ao menos uma letra minúscula (a–z)
“Senha deve conter pelo menos: digit”	Falta número	Adicionar ao menos um dígito (0–9)
“Senha deve conter pelo menos: special”	Falta caractere especial	Adicionar símbolo como ! , @ , # , \$
“Senha deve ter no mínimo 8 caracteres”	Senha muito curta	Usar ao menos 8 caracteres
“Senha deve ter no máximo 128 caracteres”	Senha muito longa	Reduzir para até 128 caracteres

13. Painel de Administração

13.1 Acesso ao Painel

O painel de administração está disponível em `/admin` e é exibido no menu lateral apenas para usuários com papel `admin`. Usuários comuns que tentarem acessar esta rota verão uma mensagem de acesso negado.

Para se tornar administrador, um DBA ou administrador existente deve executar o seguinte comando SQL diretamente no banco de dados:

```
UPDATE users SET role = 'admin' WHERE email = 'seu@email.com';
```

13.2 Aba: Incidentes Globais

Esta aba exibe todos os incidentes de todos os usuários do sistema em uma tabela unificada. As colunas incluem ID, título, categoria, risco, confiança, usuário responsável e data de registro.

Os filtros disponíveis são os mesmos da listagem pessoal (categoria, risco, busca por texto), mas aplicados globalmente sobre todos os incidentes do sistema.

Reclassificação Manual: Ao clicar no botão de reclassificação de um incidente, um diálogo permite selecionar uma nova categoria e um novo nível de risco. Esta operação substitui a classificação automática do modelo ML e é registrada no banco de dados com os novos valores.

13.3 Aba: Usuários

Esta aba lista todos os usuários cadastrados com nome, e-mail, papel atual e data de cadastro. O administrador pode alternar o papel de qualquer usuário entre `user` e `admin` com um clique no botão de alternância.

Restrição de segurança: Um administrador não pode alterar seu próprio papel para evitar bloqueio acidental do sistema.

13.4 KPIs Globais

O painel exibe quatro KPIs consolidados de todo o sistema: total de incidentes registrados por todos os usuários, total de usuários cadastrados, número de incidentes críticos e número de categorias ativas.

13.5 Exportação PDF Global

O botão “**Exportar Relatório Global**” gera um relatório PDF com todos os incidentes do sistema, incluindo a coluna de usuário responsável por cada registro. Este relatório é útil para auditorias e apresentações de gestão.

13.6 Gestão de Categorias de Incidentes

A tela de gestão de categorias está disponível em `/admin/categories` e é acessível apenas por administradores. Ela permite criar, editar e desativar as categorias utilizadas na classificação de incidentes.

Categorias padrão pré-cadastradas:

Categoria	Descrição	Cor Padrão
Phishing	Ataques de engenharia social por e-mail ou link falso	Vermelho (#f87171)
Malware	Vírus, ransomware, trojans e código malicioso	Laranja (#fb923c)
Força Bruta	Tentativas repetidas de login ou quebra de senha	Amarelo (#fbbf24)
DDoS	Ataques de negação de serviço distribuído	Roxo (#a78bfa)
Vazamento de Dados	Exposição não autorizada de dados sensíveis	Rosa (#f472b6)

Operações disponíveis:

Criar nova categoria: Clique em “**Nova Categoria**”, preencha o nome (obrigatório, 2 a 100 caracteres), descrição (opcional) e cor de identificação visual (opcional). Confirme com “**Criar**”.

Editar categoria existente: Clique no ícone de lápis ao lado da categoria desejada. Altere os campos necessários e confirme com “**Salvar**”. É possível ativar ou desativar a categoria pelo campo “**Ativa**”.

Excluir categoria: Clique no ícone de lixeira. A exclusão é lógica (soft delete): a categoria é marcada como inativa, mas o histórico de incidentes associados é preservado.

***Nota:** Categorias inativas não aparecem nas opções de filtro e classificação de novos incidentes, mas os incidentes já registrados com essa categoria permanecem inalterados.*

14. Exportação de Relatórios PDF

14.1 Como Exportar

O sistema oferece exportação de relatórios PDF em três pontos da interface:

Dashboard: O botão “Exportar PDF” gera um relatório com todos os incidentes do usuário autenticado, sem filtros.

Listagem de Incidentes: O botão “Exportar PDF” gera um relatório com os incidentes correspondentes aos filtros ativos no momento da exportação (categoria e/ou risco selecionados).

Painel de Administração: O botão “Exportar Relatório Global” gera um relatório com todos os incidentes de todos os usuários (modo admin).

14.2 Conteúdo do Relatório

O PDF gerado contém as seguintes seções:

Seção	Conteúdo
Cabeçalho	Nome do usuário, e-mail, data de geração, total de incidentes
Resumo por Categoria	Tabela com contagem de incidentes por categoria
Resumo por Risco	Tabela com contagem de incidentes por nível de risco
Tabela de Incidentes	Listagem detalhada com ID, título, categoria, risco, confiança e data

No modo admin, a tabela de incidentes inclui uma coluna adicional com o nome do usuário que registrou cada incidente.

14.3 Download Automático

O arquivo é baixado automaticamente pelo navegador com o nome `relatorio_incidentes_YYYY-MM-DD.pdf`. O tema visual SOC Portal dark é aplicado ao PDF com paleta profissional e tipografia Inter.

15. Notificações de Risco Crítico

15.1 Funcionamento

Sempre que um incidente é classificado com nível de risco **crítico** (categorias malware ou vazamento de dados), o sistema dispara automaticamente uma notificação ao administrador do sistema.

A notificação é enviada de forma assíncrona, sem impacto no tempo de resposta da operação de registro do incidente.

15.2 Conteúdo da Notificação

A notificação enviada ao administrador contém as seguintes informações:

Campo	Exemplo
Título	[ALERTA CRÍTICO] Novo incidente de segurança
Categoria	Malware
Título do Incidente	“Ransomware detectado no servidor de produção”
Usuário	nome@empresa.com
Data/Hora	07/04/2025 às 14:32

15.3 Configuração

As notificações são enviadas para o proprietário do sistema configurado nas variáveis de ambiente `OWNER_OPEN_ID` e `OWNER_NAME`. Para receber notificações, estas variáveis devem estar corretamente configuradas no arquivo `.env`.

16. Fluxos Adicionais

Fluxo 6: Exportação de Relatório PDF

```

Usuário autenticado → Página de Listagem
→ Aplica filtros desejados (categoria, risco)
→ Clica em "Exportar PDF"
→ Backend coleta incidentes filtrados
→ Envia para servidor Flask (porta 5002)
→ ReportLab gera PDF com tema SOC Portal
→ PDF retornado como base64
→ Download automático no navegador

```

Fluxo 7: Reclassificação Manual (Admin)

```
Admin autenticado → Painel de Administração
→ Aba "Incidentes Globais"
→ Localiza incidente via busca/filtros
→ Clica em "Reclassificar"
→ Seleciona nova categoria e nível de risco
→ Confirma no diálogo
→ Backend atualiza registro no banco
→ Tabela atualizada automaticamente
```

Fluxo 8: Notificação de Risco Crítico

```
Usuário registra incidente com descrição de malware/vazamento
→ Modelo ML classifica como "malware" ou "vazamento_de_dados"
→ Backend mapeia categoria → riskLevel = "critical"
→ notifyOwner() disparado de forma assíncrona
→ Administrador recebe alerta com detalhes do incidente
→ Incidente salvo normalmente no banco
→ Usuário redirecionado para página de detalhe
```

13. Divisão de Atividades do Grupo

O sistema foi desenvolvido de forma colaborativa por uma equipe de cinco integrantes, com responsabilidades distribuídas por área de especialidade. A tabela a seguir apresenta a divisão oficial das atividades do projeto:

Área	Integrante(s)	Responsabilidades
Front-end	Nattan e Keven	Desenvolvimento de todas as interfaces React: páginas de login, registro, dashboard, listagem de incidentes, formulário de novo incidente, detalhe do incidente, análise de risco e painel de administração. Implementação do design system SOC Portal (CSS variables OKLCH, fonte Inter, sidebar compacta, badges de severidade coloridos). Integração com hooks tRPC e componentes shadcn/ui.
Back-end	Margefson	Implementação completa da API tRPC com Express: routers de autenticação (bcryptjs, JWT), incidentes, administração e exportação de relatórios. Validação de entradas com Joi (incluindo regras robustas de complexidade de senha), controle de acesso por papel (user/admin), 8 requisitos de segurança (helmet, CORS, rate limiting, IDOR), integração com serviços Flask internos e suite de 200 testes Vitest (incluindo testes de consistência do design system SOC Portal, CRUD de categorias, recomendações de segurança contextualizadas e classificação automática por Machine Learning).
Banco de Dados	Nattan	Modelagem do schema relacional com Drizzle ORM: definição das tabelas <code>users</code> e <code>incidents</code> , tipos enumerados para categoria e nível de risco, configuração das migrações automáticas e implementação dos helpers de consulta em <code>server/db.ts</code> .
Classificador ML	Josias e Keven	Construção do pipeline de classificação: pré-processamento do dataset de 2000 amostras, vetorização TF-IDF (5.000 features, bigramas) e classificador Multinomial Naive Bayes. Servidor Flask de classificação (porta 5001) e servidor Flask de geração de relatórios PDF com ReportLab (porta 5002).

14. Correções de Bugs (v5.0)

BUG-001: Erro ao Criar Categoria sem Descrição

Sintoma: Ao criar uma nova categoria deixando o campo “Descrição” em branco, o sistema exibia a mensagem `Failed query: insert into categories` com os parâmetros incorretos.

Causa: O frontend enviava `description: undefined` quando o campo estava vazio. O tRPC/Zod omitia o campo do objeto, e o Drizzle ORM gerava um SQL com parâmetros na ordem errada (o nome era inserido duas vezes).

Correção: O frontend agora envia `description: ""` (string vazia) explicitamente quando o campo está em branco, garantindo que o INSERT SQL receba sempre os parâmetros na ordem correta.

BUG-002: Rota /admin/users Retornava 404

Sintoma: Ao acessar o menu “Usuários” no painel de administração, o sistema exibia a página de erro 404 “Page Not Found”.

Causa: A página `AdminUsers.tsx` não havia sido criada e a rota `/admin/users` não estava registrada no `App.tsx`.

Correção: Foi criada a página `AdminUsers.tsx` com listagem completa de usuários (nome, e-mail, papel, data de criação) e funcionalidade de promoção/rebaixamento de papel (admin/user). A rota foi registrada no `App.tsx` e o link “Usuários” foi adicionado ao menu lateral do `DashboardLayout`.

Manual atualizado em Abril de 2026 — Versão 5.0. Para suporte técnico, consulte o repositório: https://github.com/margefson/incident_security_system

7. Gerenciamento de Usuários (Admin)

O painel **Usuários** no menu de administração permite controle completo sobre os usuários cadastrados.

7.1 Editar Dados do Usuário

1. Acesse **Admin** → **Usuários**
2. Localize o usuário na tabela
3. Clique no ícone de lápis () na coluna **Ações**
4. Altere o **Nome** e/ou **Email** no formulário
5. Clique em **Salvar Alterações**

7.2 Resetar Senha

Caso um usuário esqueça sua senha, o administrador pode redefini-la para o valor padrão:

1. Clique no ícone de chave () na linha do usuário
2. Confirme a operação no diálogo
3. A senha será redefinida para **Security2026@**
4. Oriente o usuário a alterar a senha no primeiro acesso via **Meu Perfil** → **Alterar Senha**

7.3 Excluir Usuário

Atenção: A exclusão é **irreversível** e remove todos os incidentes e histórico do usuário.

1. Clique no ícone de lixeira () na linha do usuário
2. Leia o aviso de confirmação
3. Clique em **Excluir Permanentemente**

7.4 Promover / Rebaixar Perfil

- **Promover para Admin:** clique em **Promover** — o usuário ganha acesso ao painel administrativo
- **Rebaixar para Usuário:** clique em **Rebaixar** — o usuário perde o acesso ao painel

***Nota de Segurança:** O administrador não pode editar, excluir ou resetar a própria conta via painel admin. Use a página **Meu Perfil** para gerenciar seus próprios dados.*

8. Dataset e Retreinamento ML

8.1 Download do Dataset

No menu **Admin** → **Machine Learning**, seção **Dataset de Treinamento**:

- Clique em **Download XLSX** para baixar o arquivo `incidentes_cybersecurity_2000.xlsx`
- Clique em **Visualizar Online** para abrir a planilha no Microsoft Office Online (sem instalação)

8.2 Retreinamento Dinâmico

O botão **Retreinar Modelo** usa automaticamente:

1. Todos os incidentes cadastrados no banco de dados (de todos os usuários)
2. O dataset original de 2000 amostras
3. As novas amostras adicionadas manualmente no formulário

Isso garante que novas categorias cadastradas sejam incorporadas ao modelo automaticamente.

Sessão 8 — Dataset Atualizado (2000 Amostras)

O modelo de Machine Learning foi retreinado com um dataset expandido de **2000 registros** de incidentes de cibersegurança, substituindo o dataset anterior de 100 amostras.

Melhorias do Novo Dataset

Métrica	Dataset Anterior	Novo Dataset
Total de amostras	100	2000
Amostras por categoria	20	400
Acurácia de treino	100%	100%
Acurácia CV (5-fold)	97%	97%

Download do Dataset

O arquivo `incidentes_cybersecurity_2000.xlsx` está disponível para download no painel de Machine Learning (perfil admin).

Sessão 10 — Mapa Completo de Rotas da Aplicação

Esta seção documenta todas as páginas acessíveis no sistema e como navegar entre elas.

Rotas Públicas (sem necessidade de login)

As rotas públicas podem ser acessadas por qualquer visitante, mesmo sem conta cadastrada.

Endereço (URL)	Página	Descrição
/	Página Inicial	Landing page do sistema. Redireciona automaticamente para <code>/dashboard</code> se o usuário já estiver autenticado
<code>/login</code>	Login	Formulário de autenticação com e-mail e senha. Contém o link “Esqueci minha senha” para recuperação de acesso
<code>/register</code>	Cadastro	Formulário de criação de conta com checklist visual de força de senha em tempo real
<code>/reset-password?token=...</code>	Redefinição de Senha	Página para criar nova senha usando o link recebido por e-mail (token de 48 bytes, válido por 10 minutos)
<code>/404</code>	Página Não Encontrada	Exibida automaticamente para qualquer URL não reconhecida pelo sistema

Rotas Autenticadas (requerem login)

As rotas a seguir redirecionam para `/login` caso o usuário não possua sessão ativa.

Endereço (URL)	Página	Descrição
/dashboard	Painel de Controle	Visão geral com KPIs, gráficos de distribuição por categoria e risco, e lista dos incidentes mais recentes
/incidents	Listagem de Incidentes	Tabela paginada com filtros avançados por categoria, nível de risco e período. Suporta busca de texto e exportação CSV/PDF
/incidents/new	Novo Incidente	Formulário para registrar um incidente com classificação automática por Machine Learning
/incidents/:id	Detalhe do Incidente	Página completa: metadados, status, notas, histórico de alterações e recomendações de segurança
/risk	Análise de Risco	Painel analítico com KPIs de risco, gráfico por nível de risco e recomendações contextualizadas
/profile	Perfil do Usuário	Dados pessoais, estatísticas individuais e seção para alteração de senha

Rotas Administrativas (requerem papel admin)

As rotas administrativas exibem “Acesso Negado” para usuários com papel `user` .

Endereço (URL)	Página	Descrição
/admin	Hub Administrativo	Página central com acesso rápido às três áreas de administração
/admin/categories	Gerenciar Categorias	CRUD completo de categorias de incidentes: criar, editar, ativar/desativar e excluir
/admin/users	Gerenciar Usuários	Listagem de todos os usuários com opções para editar, alterar papel, resetar senha e excluir
/admin/ml	Machine Learning	Métricas do modelo, download do dataset, visualização online e retreinamento

Navegação pelo Sistema

O sistema utiliza uma barra lateral persistente em todas as páginas autenticadas. Os itens disponíveis dependem do papel do usuário:

Usuários comuns visualizam: Dashboard, Incidentes, Novo Incidente, Análise de Risco.

Administradores visualizam adicionalmente: Administração (com submenu para Categorias, Usuários e Machine Learning).

O menu do perfil (canto superior direito da sidebar) oferece acesso à página de Perfil e à opção de Logout.